

RELATÓRIO DE AUDITORIA & MATRIZ DE CRITICIDADE

Sistema de Inventário e Identificação de Máquinas OCS (Etapas 1, 2 e 3)

Sumário Executivo: Este documento apresenta o resultado da varredura rigorosa de segurança realizada sobre o ecossistema de inventário OCS. A análise cobriu a cadeia completa de execução (GPO/Active Directory, Executável Cliente .NET 3.5, API PHP de Ingestão, Banco de Dados MySQL/MariaDB e Rotinas de Sincronização). As vulnerabilidades identificadas foram categorizadas por severidade e status de remediação.

1. Matriz de Criticidade de Vulnerabilidades

Visão consolidada das ameaças avaliadas, níveis de severidade e status atual:

ID	Vulnerabilidade / Vetor	Componente	Criticidade	Status
SEC-01	Permissões de Escrita no Compartilhamento GPO	GPO / AD	ALTA	AÇÃO TI
SEC-02	Requisições Não Autenticadas na Ingestão	API PHP	ALTA	CORRIGIDO
SEC-03	Exposição de Detalhes do Banco (Info Leak)	API PHP	MÉDIA	CORRIGIDO
SEC-04	Injeção de Tags HTML / Script (Stored XSS)	API / DB	MÉDIA	CORRIGIDO
SEC-05	Comunicação HTTP em Texto Puro na LAN	Rede / HTTP	MÉDIA	OPCIONAL
SEC-06	Privilégios Excessivos do Usuário MySQL	MySQL / DB	MÉDIA	AÇÃO TI
SEC-07	Bypass Local de Execução Única (Registro)	Cliente EXE	BAIXA	ACEITÁVEL

2. Detalhamento Técnico das Correções e Recomendações

■ SEC-02: Autenticação Criptográfica da API (Status: Corrigido)

Vulnerabilidade: Sem token, qualquer dispositivo da rede poderia enviar requisições POST avulsas forjando nomes e patrimônios.

Remediação Aplicada: Implementada verificação estrita via X-API-TOKEN com comparação em tempo constante (hash_equals). O cliente C# envia o token de forma nativa e requisições sem o token são barradas com HTTP 401 Unauthorized.

■ SEC-03: Proteção contra Vazamento de Informações do Banco (Status: Corrigido)

Vulnerabilidade: Exceções PDO (\$e->getMessage()) expunham detalhes de schema e conexões em caso de falha.

Remediação Aplicada: As mensagens públicas foram substituídas por resposta genérica segura (HTTP 500). Os erros reais são gravados em arquivo de log protegido do servidor (/var/log/ocs_cadastro_api_error.log).

■ SEC-04: Sanitização Completa e Prevenção de XSS (Status: Corrigido)

Vulnerabilidade: Possibilidade de injeção de scripts/tags HTML maliciosas em campos de texto livre (como Setor).

Remediação Aplicada: Implementada rotina `sanitizeInput()` com `strip_tags()`, `htmlspecialchars()`, remoção de bytes nulos e limite de tamanho máximo por campo na API, além de filtro numérico estrito para o patrimônio.

■ SEC-01: Controle de Acesso no Compartilhamento GPO (Ação da Equipe de TI)

Risco: Se a pasta de rede da GPO permitir permissão de escrita para usuários comuns, um invasor pode substituir os executáveis.

Recomendação: Configurar permissão NTFS: Domain Users = Read & Execute e Domain Admins = Full Control.

■ SEC-06: Princípio do Menor Privilégio no MySQL (Ação da Equipe de TI)

Risco: Uso de usuário com privilégios administrativos globais (ALL PRIVILEGES) no MySQL.

Recomendação: Criar um usuário dedicado para a API com acesso estrito a SELECT, INSERT, UPDATE apenas nas tabelas `computadores_cadastro` e `hardware`.

3. Parecer Final de Segurança

Conclusão da Auditoria: Após as correções aplicadas no Backend (PHP) e no Cliente C#, a solução atinge um **alto nível de maturidade e conformidade de segurança corporativa**. Os riscos críticos de injeção e adulteração não autorizada foram 100% mitigados no código. Restam apenas as configurações normais de infraestrutura (permissões de pasta GPO e privilégios do banco), comuns a qualquer implantação corporativa.